

24 AUGUST 2026

PHISHING EMAIL DETECTION & THREAT ANALYSIS REPORT

Assessor: Anil Kashyap

GitHub

LinkedIn

EXECUTIVE SUMMARY

Phishing remains a primary attack vector, relying on social engineering to bypass technical defenses. For this assessment, two raw .eml files captured via honeypots were analyzed using Email Header Analyzer tools. The objective is to identify the technical Indicators of Compromise (IoCs) hidden in the email routing data and provide actionable awareness guidelines for employees.

TECHNICAL CASE STUDIES (HEADER ANALYSIS)

Case Study 1: The Microsoft Account Credential Harvester

- Risk Classification:  PHISHING (High Risk)
- Attack Mechanism: A credential harvesting attempt using fear and urgency. It alerts the user to an "unusual sign-in activity from Russia" to panic them into interacting with a malicious "Report The User" link.

KEY TECHNICAL INDICATORS OF COMPROMISE (IOCS):

- Authentication & Reputation Failures: Header analysis reveals Authentication-Results: spf=none and dmarc=permerror. The sending IP (89.144.44.2) lacks the necessary DNS records to authenticate the message.
- Spoofed Corporate Identity: The From: display name reads "Microsoft account team", but the actual sender is no-reply@access-accsecurity.com. Legitimate alerts originate from official microsoft.com domains.
- Suspicious Reply Path: The Reply-To: header directs responses to sotrecognizd@gmail.com. A legitimate corporate security alert will never direct replies to a free, disposable Gmail address.
- Hidden Tracking Pixel: The HTML body contains a 1x1 tracking pixel (http://thebandalisty.com/track/... with visibility:hidden) designed to notify the attacker when the email is opened.

Case Study 2: The "Zonnepanelen" (Solar Panel) Spam Campaign

- *Risk Classification:* ● SUSPICIOUS (Lead Generation/ Spam)
- *Attack Mechanism:* Exploits consumer interest in energy savings by offering solar panels. The goal is likely fraudulent lead generation via malicious affiliate links.

KEY TECHNICAL INDICATORS OF COMPROMISE (IOCS):

- *Infrastructure Discrepancies:* There is a complete mismatch between the From: domain (appjj.serenitepure.fr) and the Reply-To: domain (news@aichakandisha.com).
- *Failed Composite Authentication:* The headers show compauth=fail reason=001, indicating the email failed Microsoft Office 365's internal authentication checks.
- *Honeypot Targeting:* The To: field explicitly lists phishing@pot, confirming this was part of a mass-mailing "spray and pray" campaign rather than a targeted spear-phishing attack.



EMPLOYEE DEFENSE & AWARENESS GUIDELINES

The "STOP, LOOK, THINK" Protocol

1. STOP: Beware of Emotional Triggers

Phishing relies on panic (e.g., "Unusual sign-in from Russia") or greed (e.g., "Solar panels for a good price"). If an email triggers a strong emotional response, pause before interacting.

2. LOOK: Inspect the Hidden Details

- **Verify the Sender:** Never trust the "Display Name" (e.g., "Microsoft account team"). Always inspect the actual email address in the < > brackets.
- **The "Reply-To" Trap:** If you hit "Reply," check where the email is actually going. If it switches from a corporate domain to a Gmail or Yahoo account, it is likely a scam.
- **Hover Before Clicking:** Hover your mouse over buttons. Look at the bottom corner of your screen to verify the true destination URL.

3. THINK: Verify Independently

Never Log In Via Email Links: If an email claims your account is compromised, do not use the provided links. Open a fresh browser window, manually navigate to the official website, and log in securely.

WHAT TO DO IF YOU SPOT A PHISH

- Do NOT reply, click links, or download attachments.
- Report It: Forward the suspicious email (preferably as an attachment) to your internal IT Security team.
- Delete It: Remove the email from your inbox immediately after reporting.